115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 04 月 11 日

一、選擇題

答案	題目
A	1. 下列何項工具可以用來盤點 Windows Server Active Directory（AD）的關連性及權限設定，發現 AD 的潛在威脅，既可被紅隊成員拿來規劃內網檢測方向，也可以被藍隊成員用來規劃 AD 資安強化措施？ (A) BloodHound (B) Snort (C) OpenVAS (D) Nmap
D	2. 下列何項屬於 MITRE ATT&CK 中的憑證存取（Credential Access）戰術（Tactic）？ (A) 從本機系統蒐集資料（Data from Local System） (B) 外部遠端服務使用（External Remote Services） (C) 清除 Windows 事件記錄（Clear Windows Event Logs） (D) 作業系統憑證傾印（OS Credential Dumping）
B	3. 駭客為了追求最大利益，將亂槍打鳥的隨機攻擊轉換成目標式攻擊，進階持續性威脅（Advanced Persistent Threats，APT）即是最難防禦的目標式攻擊。關於 APT 攻擊的敘述，下列何者最「不」適切？ (A) APT 攻擊常透過社交工程結合零時差（Zero-day）漏洞取得初始入侵點 (B) APT 行動通常僅在短時間內完成，整個攻擊週期不會超過 24 小時 (C) 攻擊者會建立多條指揮控制（C2）通道，以降低被完全阻斷的風險 (D) APT 攻擊往往伴隨嚴謹的情報蒐集與量身訂做的惡意程式，以提高成功率
AC	4. 下列哪些攻擊手法可以透過遠端攻擊網路伺服器？（複選） (A) Slowloris 攻擊 (B) BlueBorne 攻擊 (C) SQL 指令注入（SQL Injection） (D) Evil Twin 攻擊

B

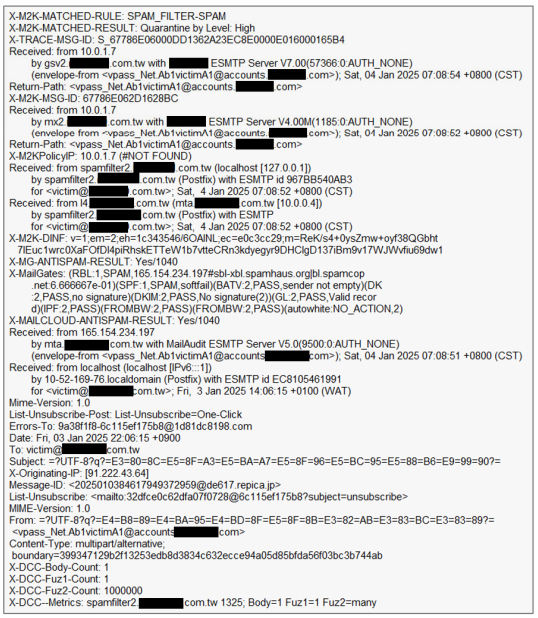
5. 【題組 1】情境如附圖所示。關於信件中出現 Received: from 10.0.1.7 的本地 IP 地址，下列何項敘述最為適切？

網路詐騙十分猖獗，公司一位高階主管，被一封釣魚信件欺騙（圖一），點擊信件中的連結，並且連結 C2 中繼站，植入惡意程式，竊取該位主管瀏覽器的帳號與密碼，其中包含了連接公司 Exchange 帳號與密碼...趕緊尋求公司資安部門進行鑑識分析，結果從信件標頭及詳細資訊發現到以下資訊（圖二），身為資安事件威脅攻擊之鑑識人員你（妳），請依據這兩項鑑識資訊，回答本題組之相關問題。

圖一



圖二



(A) 此 IP 為原始發信者 IP

(B) 攻擊者可能隱藏其實際來源

(C) 本地 IP 位址保證了信件的安全性

(D) 信件已通過多重身份驗證

B

6. 【題組 1】情境如附圖所示。從圖二資訊中，發現郵件來源的網域金鑰識別郵件（DomainKeys Identified Mail，DKIM）簽名為"No signature"時，應採取下列何項的對應行動最為適切合理？

網路詐騙十分猖獗，公司一位高階主管，被一封釣魚信件欺騙（圖一），點擊信件中的連結，並且連結 C2 中繼站，植入惡意程式，竊取該位主管瀏覽器的帳號與密碼，其中包含了連接公司 Exchange 帳號與密碼…趕緊尋求公司資安部門進行鑑識分析，結果從信件標頭及詳細資訊發現到以下資訊（圖二），身為資安事件威脅攻擊之鑑識人員你（妳），請依據這兩項鑑識資訊，回答本題組之相關問題。

圖一



圖二



(A) 自動信任此郵件，因為 DKIM 簽名不是必要的安全措施

(B) 驗證信件來源，並檢查是否有其可疑疑慮

(C) 立即刪除信件，因為這意味著信件一定是惡意的

(D) 啟用防火牆來阻止所有與該域相關的通信

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 04 月 11 日

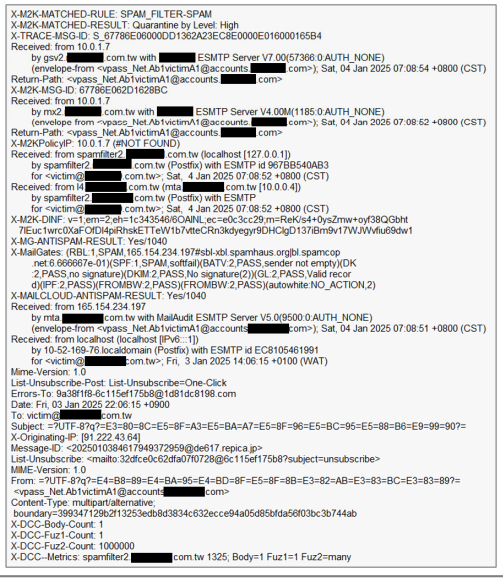
答案	題目
A	7. 【題組 1】情境如附圖所示。如果通過 VirusTotal 等工具，發現網址被標記為惡意，身為專業資安人員應該採取下列何項處置最為適切？

網路詐騙十分猖獗，公司一位高階主管，被一封釣魚信件欺騙（圖一），點擊信件中的連結，並且連結 C2 中繼站，植入惡意程式，竊取該位主管瀏覽器的帳號與密碼，其中包含了連接公司 Exchange 帳號與密碼…趕緊尋求公司資安部門進行鑑識分析，結果從信件標頭及詳細資訊發現到以下資訊（圖二），身為資安事件威脅攻擊之鑑識人員你（妳），請依據這兩項鑑識資訊，回答本題組之相關問題。

圖一



圖二



(A) 立即在公司網路中封鎖該網址，並通知相關人員不要點擊

(B) 忽略不用理會判定結果，因為誤判的可能性很高

(C) 在自己工作電腦直接點擊網址，自己感受確認是否真的有安全威脅

(D) 將此網址加入瀏覽器白名單以避免誤報

AC

8. 【題組 1】情境如附圖所示。在驗證網址的安全性時，可以採取下列哪些具安全性的方式進行檢查？（複選）

網路詐騙十分猖獗，公司一位高階主管，被一封釣魚信件欺騙（圖一），點擊信件中的連結，並且連結 C2 中繼站，植入惡意程式，竊取該位主管瀏覽器的帳號與密碼，其中包含了連接公司 Exchange 帳號與密碼...趕緊尋求公司資安部門進行鑑識分析，結果從信件標頭及詳細資訊發現到以下資訊（圖二），身為資安事件威脅攻擊之鑑識人員你（妳），請依據這兩項鑑識資訊，回答本題組之相關問題。

圖一



圖二



(A) 使用 DNS 查詢工具檢查域名的註冊日期和註冊商資訊

(B) 點擊連結後檢查網站的內容是否與官方網站一致

(C) 使用 URL 檢測工具（如 VirusTotal）進行分析

(D) 根據網址中的頂級域名（如.sbs）直接判定為安全或危險

答案	題目
C	9. 針對目前時下常見的資安技術與產品中，下列何項描述較「不」正確？ (A) Breach and Attack Simulation（BAS）主要是用高頻率且大量的攻擊方式來檢驗企業當下的防禦機制是否有效 (B) External Attack Surface Management（EASM）主要是用來查核企業暴露於網路上的數位資產有哪些，例如對外開放的 port、企業持有的網域名稱、企業外洩的帳號密碼等等 (C) Security Information and Event Management（SIEM）僅用來蒐集外部常見的攻擊情資，例如其他國家或企業的攻擊事件，或是暗網上的攻擊行動預告文章，以便發現潛在的資安威脅，然後再來檢視企業是否即將面臨類似的攻擊 (D) Endpoint Detection and Response（EDR）主要是透過分析端點的日誌和行為，來發現甚至阻斷攻擊者的行動
B	10. 在導入零信任架構的微分段（Micro-segmentation）時，若目標是最大限度降低橫向移動（Lateral Movement）風險，下列何項做法最為有效？ (A) 透過虛擬區域網路將子網路進行邏輯切割 (B) 在工作負載層實施「基於身分的動態安全群組」並預設拒絕（Default-deny）所有跨段流量 (C) 僅於核心交換器設定網路存取控制列表（Access Control List, ACL） (D) 使用傳統邊界防火牆將內、外網物理隔離
B	11. 備份是目前公司營運的基本要求，其中我們在評估，還原至最接近災難發生的時間點時，依據美國國家標準技術研究院（NIST）特別出版品 800-34（SP 800-34）中的相關規定應該參考下列何項指標？ (A) 復原時間目標（Recovery Time Objective，RTO） (B) 復原點目標（Recovery Point Objective，RPO） (C) 作業重建時間（Work Recovery Time，WRT） (D) 最大可容忍停機時間（Max Tolerable Downtime，MTD）
B	12. 依 MITRE ATT&CK，若攻擊者執行 PowerShell 指令 Get-ChildItem -Recurse 快速列舉檔案，並進一步將結果外洩（exfiltrate），此行為最符合下列何項技術（technique）？ (A) T1005 Data from Local System (B) T1083 File and Directory Discovery (C) T1041 Exfiltration Over Command & Control Channel (D) T1070 Indicator Removal

答案	題目
B	13. 一家金融機構正依據最新的隱私法規（如 GDPR）要求，設計其資料外洩防護（Data Loss Prevention, DLP）策略。下列何項原則最能體現現代 DLP 的核心精神？ (A) 封鎖所有員工使用 USB 隨身碟與個人雲端儲存 (B) 基於資料的內容與情境感知，對敏感資料的移動進行分類、監控與攔截 (C) 對公司所有的網路流量進行加密，防止被竊聽 (D) 僅在偵測到惡意軟體時，才啟動資料外洩的監控
A	14. 企業採用 AWS 與 Azure 混合雲架構。經查發現多起因開發人員錯誤設定 S3 儲存桶權限導致資料外洩的事件。為持續監控並自動修正此類配置錯誤，下列何種解決方案最為適切？ (A) 導入雲端安全態勢管理（CSPM）工具 (B) 部署網頁應用程式防火牆（WAF） (C) 全面升級端點防護軟體（EPP）至最新版 (D) 在雲端虛擬機安裝入侵防禦系統（IPS）
ACD	15. 在美國國家標準技術研究院（NIST）特別出版品 800-61 Rev. 2（SP 800-61 Rev. 2）中，關於事件封鎖、根除與復原（Containment, Eradication, and Recovery）階段的主要活動描述，下列哪些最為正確？（複選） (A) 實施短期封鎖措施以減少事件影響，防止進一步擴散 (B) 根據事件影響範圍決定是否需要向主管機關進行報告 (C) 移除攻擊者在系統中的持久性威脅（如後門或惡意軟體） (D) 恢復受影響的系統至正常運行狀態，並驗證系統安全性
ABC	16. 面對利用 AI 技術生成多態（Polymorphic）惡意軟體和自動化釣魚郵件的攻擊，傳統的防禦方法已顯不足。為了有效對抗 AI 驅動的攻擊，企業應採取下列哪些防禦策略？（複選） (A) 部署基於行為分析的端點偵測與回應（Endpoint Detection and Response, EDR）系統 (B) 實施強健的資安意識培訓，並結合釣魚郵件模擬演練 (C) 採用 AI 驅動的郵件過濾系統，以識別語氣和上下文的異常 (D) 僅依賴每季更新一次的防火牆黑名單規則

C

17. 【題組 2】情境如附圖所示。因應 AI 技術的成熟和普及，W 公司已安排乙供應商擇一條產線進行新的 AOI（Automated Optical Inspection）自動光學檢測系統評估，用以提升未來產線的 QA 能力，請問在導入 AI 技術時，下列何項為「非」優先考量的 AI 或資安治理合規標準？

W公司是一家ODM公司，製造電子產品供應全球，因應下游客戶的要求，開始強化資訊安全防護與導入國際資安標準的合規認證；經與既有甲設備商確認產線上的PLC工控設備不能隨意更動，否則將會影響產線自動化功能與產品生產精確度和良率。

圖1

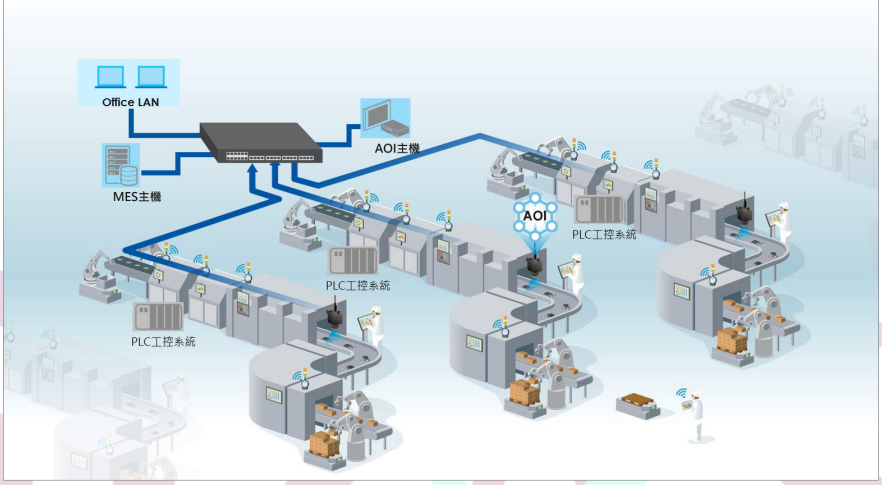
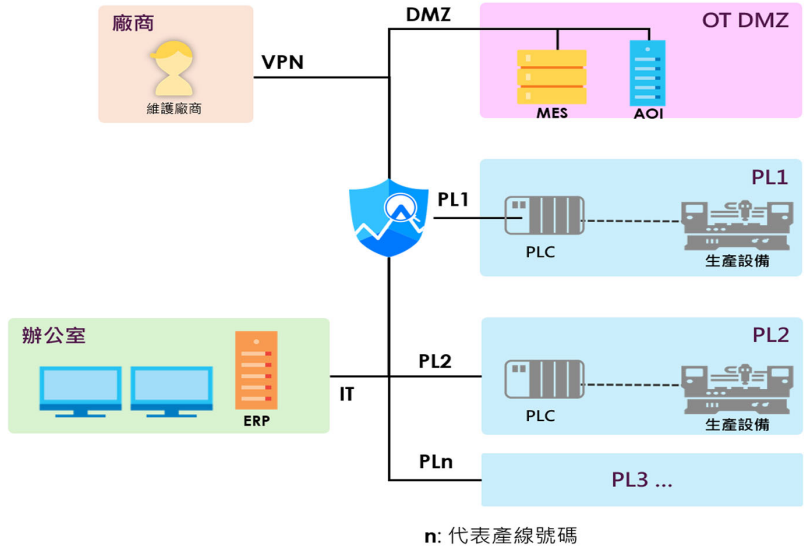


圖2

W 公司的工廠主機的弱點偵測掃瞄記錄摘要如下：

192.168.3.2 (PLC#1)		
Severity	CVSS	Name
CRITICAL	10.0	Unsupported Windows OS
HIGH	7.5	Unsupported Web Server Detection
HIGH	7.5	Microsoft Windows SMB Shares Unprivileged Access
MEDIUM	6.8	Security Update for SAM and LSAD Remote Protocols
MEDIUM	5.1	Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness
192.168.3.3 (PLC#2)		
Severity	CVSS	Name
CRITICAL	10.0	Microsoft Windows SMBv1 Multiple Vulnerabilities
CRITICAL	10.0	Unsupported Windows OS
MEDIUM	5.1	Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness
INFO	N/A	Windows Terminal Services Enabled
192.168.1.102 (MES)		
Severity	CVSS	Name
HIGH	7.5	Unsupported Web Server Detection
MEDIUM	6.5	Remote Desktop Protocol Server Man-in-the-Middle Weakness
MEDIUM	6.4	SSL Certificate Cannot Be Trusted
LOW	2.6	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
192.168.1.211 (AOI)		
Severity	CVSS	Name
CRITICAL	10.0	Python Unsupported Version Detection
CRITICAL	10.0	Microsoft SQL Server Unsupported Version Detection (remote check)
HIGH	7.3	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
MEDIUM	6.5	SSL Self-Signed Certificate
MEDIUM	5.0	mDNS Detection (Remote Network)
LOW	2.6	Terminal Services Encryption Level is not FIPS-140 Compliant

答案	題目
	圖3  n: 代表產線號碼 圖4 Conduit Firewall 設定項目： 甲. Deny All 乙. Allow All 丙. Allow IT to DMZ 丁. Deny PL*n* to IT 戊. Allow VPN to PL*n* 己. Deny PL*n* to VPN 庚. Allow IT to PL*n* 辛. Deny PL*n* to DMZ 壬. Allow PL*m* to IT 癸. Deny PL*n* to PL*m* 子. Allow DMZ to PL*m* 丑. Deny DMZ to IT 寅. Allow VPN to DMZ 卯. Deny DMZ to VPN ***n***或***m***: 代表產線號碼 (A) 行政院數位發展部「公部門人工智慧應用參考手冊（草案）」 (B) EU AI Act 歐盟 AI 法案 (C) ISO/IEC 27006 資訊安全管理系統稽核規範 (D) IEC 62443 系列工業通信網路-網路和系統的 IT 安全性標準

B

18. 【題組 2】情境如附圖所示。圖 2 為 W 公司在工廠內進行的主機弱點偵測掃瞄記錄，請問 W 公司在提升工廠生產線的資安作為，下列何項資安維護作業較「不」合適？

W公司是一家ODM公司，製造電子產品供應全球，因應下游客戶的要求，開始強化資訊安全防護與導入國際資安標準的合規認證；經與既有甲設備商確認產線上的PLC工控設備不能隨意更動，否則將會影響產線自動化功能與產品生產精確度和良率。

圖1

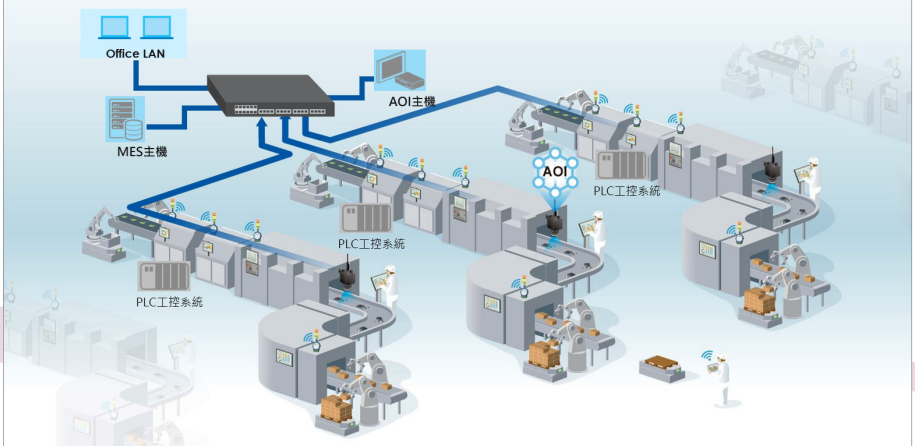
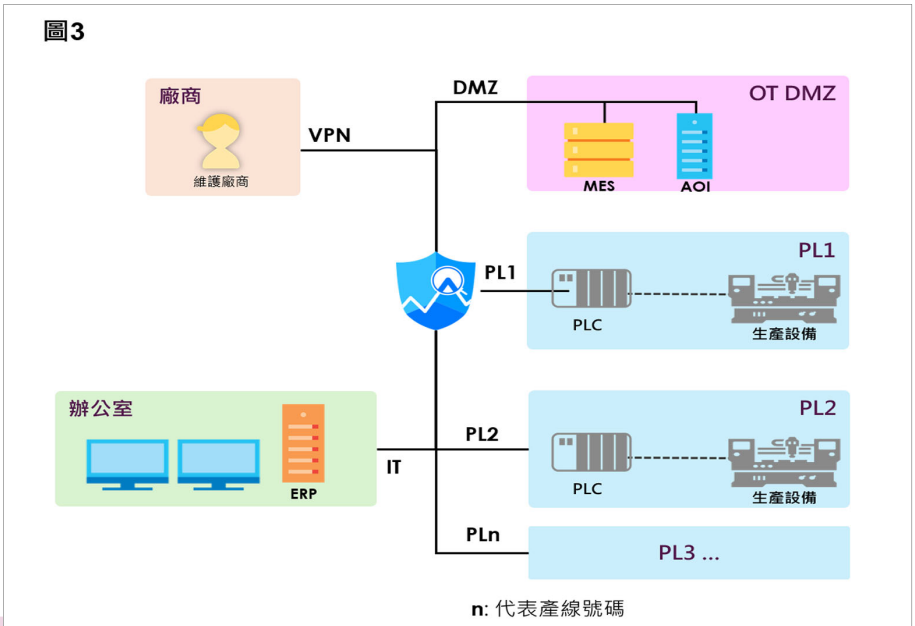


圖2

W 公司的工廠主機的弱點偵測掃瞄記錄摘要如下：

192.168.3.2 (PLC#1)		
Severity	CVSS	Name
CRITICAL	10.0	Unsupported Windows OS
HIGH	7.5	Unsupported Web Server Detection
HIGH	7.5	Microsoft Windows SMB Shares Unprivileged Access
MEDIUM	6.8	Security Update for SAM and LSAD Remote Protocols
MEDIUM	5.1	Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness
192.168.3.3 (PLC#2)		
Severity	CVSS	Name
CRITICAL	10.0	Microsoft Windows SMBv1 Multiple Vulnerabilities
CRITICAL	10.0	Unsupported Windows OS
MEDIUM	5.1	Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness
INFO	N/A	Windows Terminal Services Enabled
192.168.1.102 (MES)		
Severity	CVSS	Name
HIGH	7.5	Unsupported Web Server Detection
MEDIUM	6.5	Remote Desktop Protocol Server Man-in-the-Middle Weakness
MEDIUM	6.4	SSL Certificate Cannot Be Trusted
LOW	2.6	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
192.168.1.211 (AOI)		
Severity	CVSS	Name
CRITICAL	10.0	Python Unsupported Version Detection
CRITICAL	10.0	Microsoft SQL Server Unsupported Version Detection (remote check)
HIGH	7.3	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
MEDIUM	6.5	SSL Self-Signed Certificate
MEDIUM	5.0	mDNS Detection (Remote Network)
LOW	2.6	Terminal Services Encryption Level is not FIPS-140 Compliant

答案	題目
	圖3  n: 代表產線號碼 圖4 Conduit Firewall 設定項目： 甲. Deny All 乙. Allow All 丙. Allow IT to DMZ 丁. Deny PL*n* to IT 戊. Allow VPN to PL*n* 己. Deny PL*n* to VPN 庚. Allow IT to PL*n* 辛. Deny PL*n* to DMZ 壬. Allow PL*m* to IT 癸. Deny PL*n* to PL*m* 子. Allow DMZ to PL*m* 丑. Deny DMZ to IT 寅. Allow VPN to DMZ 卯. Deny DMZ to VPN ***n***或***m***: 代表產線號碼 (A) 修補計劃導入的 AOI 系統源碼掃瞄的高風險項目 (B) 更新非產線的 Windows 作業系統工作站至最新發布的版本 (C) 規劃虛擬補丁（Virtual Patching）機制，保護實體防護不足與無法更新修補的設備與工控系統 (D) 修補 AOI 主機系統的弱點掃瞄和滲透測試的高風險項目

BCD

19. 【題組 2】情境如附圖所示。W 公司將依據 NIST SP 800-207 的微分割（Micro-Segmentation）方法，將在 IEC 62443 的工控場域中重新配置 Zone 與 Conduit 的網路規劃，請問下列何項為分割區域管理的資安目的？（複選）

W公司是一家ODM公司，製造電子產品供應全球，因應下游客戶的要求，開始強化資訊安全防護與導入國際資安標準的合規認證；經與既有甲設備商確認產線上的PLC工控設備不能隨意更動，否則將會影響產線自動化功能與產品生產精確度和良率。

圖1

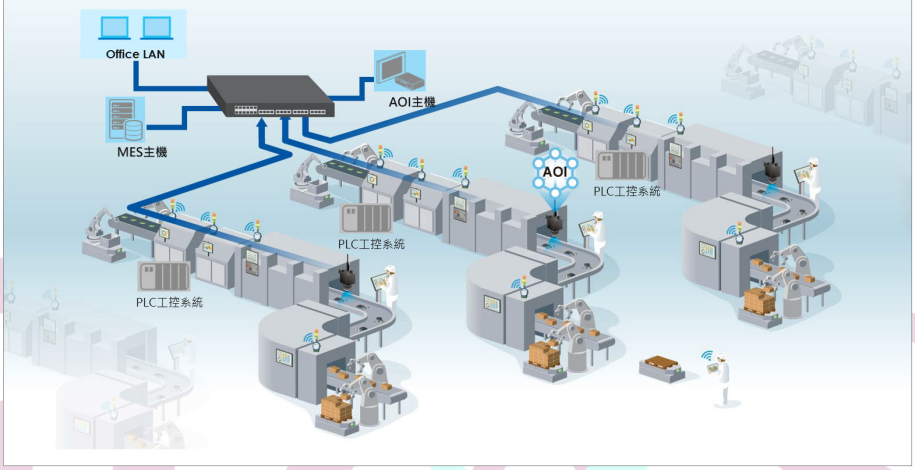
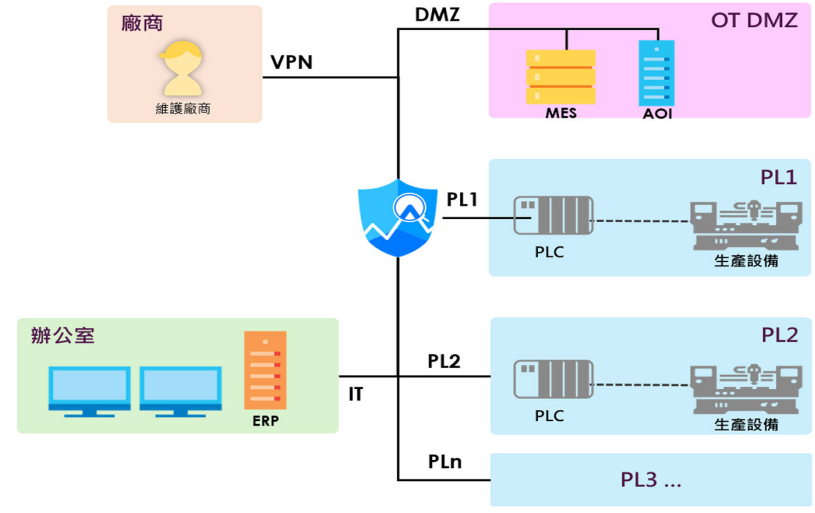


圖2

W 公司的工廠主機的弱點偵測掃瞄記錄摘要如下：

192.168.3.2 (PLC#1)		
Severity	CVSS	Name
CRITICAL	10.0	Unsupported Windows OS
HIGH	7.5	Unsupported Web Server Detection
HIGH	7.5	Microsoft Windows SMB Shares Unprivileged Access
MEDIUM	6.8	Security Update for SAM and LSAD Remote Protocols
MEDIUM	5.1	Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness
192.168.3.3 (PLC#2)		
Severity	CVSS	Name
CRITICAL	10.0	Microsoft Windows SMBv1 Multiple Vulnerabilities
CRITICAL	10.0	Unsupported Windows OS
MEDIUM	5.1	Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness
INFO	N/A	Windows Terminal Services Enabled
192.168.1.102 (MES)		
Severity	CVSS	Name
HIGH	7.5	Unsupported Web Server Detection
MEDIUM	6.5	Remote Desktop Protocol Server Man-in-the-Middle Weakness
MEDIUM	6.4	SSL Certificate Cannot Be Trusted
LOW	2.6	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
192.168.1.211 (AOI)		
Severity	CVSS	Name
CRITICAL	10.0	Python Unsupported Version Detection
CRITICAL	10.0	Microsoft SQL Server Unsupported Version Detection (remote check)
HIGH	7.3	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
MEDIUM	6.5	SSL Self-Signed Certificate
MEDIUM	5.0	mDNS Detection (Remote Network)
LOW	2.6	Terminal Services Encryption Level is not FIPS-140 Compliant

答案	題目
	圖3  n: 代表產線號碼 圖4 Conduit Firewall 設定項目： 甲. Deny All　乙. Allow All 丙. Allow IT to DMZ　丁. Deny PL*n* to IT 戊. Allow VPN to PL*n*　己. Deny PL*n* to VPN 庚. Allow IT to PL*n*　辛. Deny PL*n* to DMZ 壬. Allow PL*m* to IT　癸. Deny PL*n* to PL*m* 子. Allow DMZ to PL*m*　丑. Deny DMZ to IT 寅. Allow VPN to DMZ　卯. Deny DMZ to VPN ***n***或***m***: 代表產線號碼 (A) 所有協同作業的資產必須規劃在同區域內，預設互相信任確保工控系統最小化調整 (B) 降低系統被入侵後，攻擊者在內部網路橫向移動的能力 (C) 可針對每個區域設定對應的安全等級（Security Level） (D) 將資源分區管理，每個請求皆需通過即時驗證與授權，限制攻擊範圍

D

20. 【題組 2】情境如附圖所示。W 公司計劃將工廠的網路分割為不同區域，分別獨立出個別產線單元，並將主機設備集中到 OT DMZ 網段之中，在不提供工控系統連接外部網路的狀況下，可於必要時啟用 VPN 帳號，使維護廠商得以用 VPN 進行連線作業，圖 3 網路分割區塊規劃，請依圖 4 中的路由管理項目，本場域的 IEC 62443 Conduit 防火牆，下列何者為較佳的防火牆政策設定？

W公司是一家ODM公司，製造電子產品供應全球，因應下游客戶的要求，開始強化資訊安全防護與導入國際資安標準的合規認證；經與既有甲設備商確認產線上的PLC工控設備不能隨意更動，否則將會影響產線自動化功能與產品生產精確度和良率。

圖1

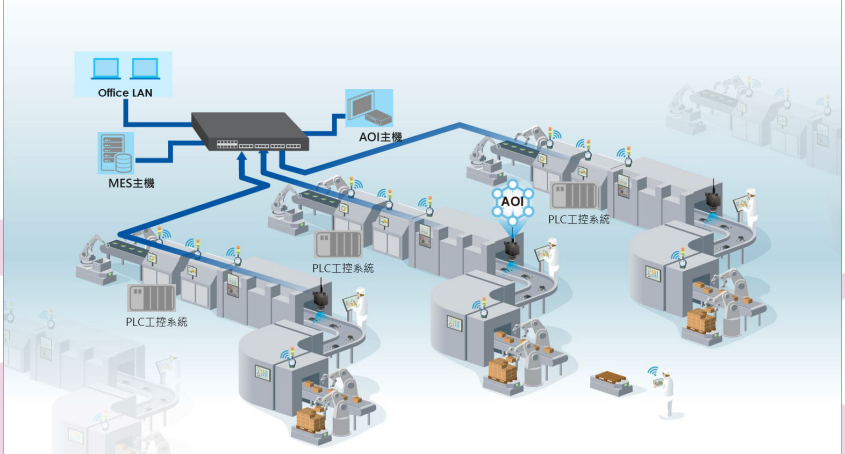
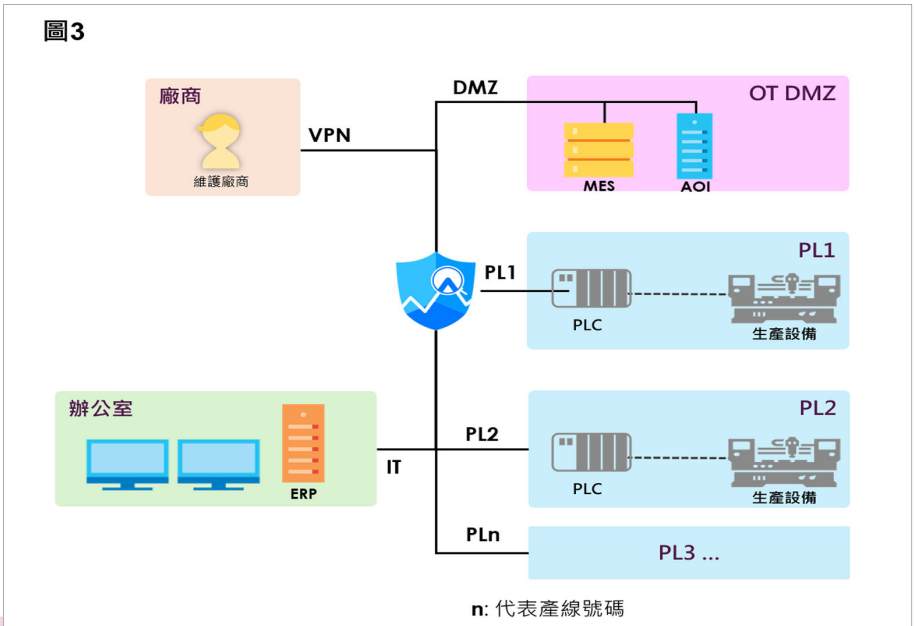


圖2

W 公司的工廠主機的弱點偵測掃瞄記錄摘要如下：

192.168.3.2 (PLC#1)		
Severity	CVSS	Name
CRITICAL	10.0	Unsupported Windows OS
HIGH	7.5	Unsupported Web Server Detection
HIGH	7.5	Microsoft Windows SMB Shares Unprivileged Access
MEDIUM	6.8	Security Update for SAM and LSAD Remote Protocols
MEDIUM	5.1	Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness
192.168.3.3 (PLC#2)		
Severity	CVSS	Name
CRITICAL	10.0	Microsoft Windows SMBv1 Multiple Vulnerabilities
CRITICAL	10.0	Unsupported Windows OS
MEDIUM	5.1	Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness
INFO	N/A	Windows Terminal Services Enabled
192.168.1.102 (MES)		
Severity	CVSS	Name
HIGH	7.5	Unsupported Web Server Detection
MEDIUM	6.5	Remote Desktop Protocol Server Man-in-the-Middle Weakness
MEDIUM	6.4	SSL Certificate Cannot Be Trusted
LOW	2.6	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
192.168.1.211 (AOI)		
Severity	CVSS	Name
CRITICAL	10.0	Python Unsupported Version Detection
CRITICAL	10.0	Microsoft SQL Server Unsupported Version Detection (remote check)
HIGH	7.3	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
MEDIUM	6.5	SSL Self-Signed Certificate
MEDIUM	5.0	mDNS Detection (Remote Network)
LOW	2.6	Terminal Services Encryption Level is not FIPS-140 Compliant

答案	題目
	圖3  圖4 Conduit Firewall 設定項目： 甲. Deny All　乙. Allow All 丙. Allow IT to DMZ　丁. Deny PL*n* to IT 戊. Allow VPN to PL*n*　己. Deny PL*n* to VPN 庚. Allow IT to PL*n*　辛. Deny PL*n* to DMZ 壬. Allow PL*m* to IT　癸. Deny PL*n* to PL*m* 子. Allow DMZ to PL*m*　丑. Deny DMZ to IT 寅. Allow VPN to DMZ　卯. Deny DMZ to VPN ***n***或***m***: 代表產線號碼 (A) 癸丁己辛丑乙 (B) 乙己辛癸丑卯 (C) 甲壬子寅丙 (D) 丙寅子戊甲
B	21. 依據《資通安全管理法》及鑑識需求，針對關鍵資產的日誌（Logs）管理策略，下列何項實作最能確保日誌的「不可否認性（Non-repudiation）」與完整性？ (A) 將日誌儲存於本地端伺服器，並設定唯讀權限 (B) 透過 Syslog 將日誌即時拋送至遠端專用伺服器，並實施數位簽章或雜湊鏈結 (C) 定期將日誌備份至 USB 硬碟，並由專人保管鎖入保險箱 (D) 設定日誌檔案滿額後自動覆蓋舊資料，以節省儲存空間

答案	題目
D	22. 就勒索軟體事件而言，最有可能降低事件衝擊的控制措施為下列何項？ (A) 原始碼檢測 (B) 日誌分析 (C) 社交工程演練 (D) 離線資料備份
C	23. 資安團隊收到弱點掃描報告共 2,000 個弱點，其中包含：對外系統的高風險 RCE（Remote Code Execution）、內網測試機的重大風險弱點、以及多台使用者端的低風險資訊揭露。公司高層希望資安團隊說明弱點修補的優先順序，若以公司風險控管的角度來考量，資安團隊應該優先採取下列何項較為合適？ (A) 先修數量最多的同一種弱點，因為最能降低弱點總量 (B) 依 CVSS（Common Vulnerability Scoring System）由高到低，全部照順序修補 (C) 修補「對外暴露且可利用」的高風險弱點，再依資產重要性與可利用性排序 (D) 先修使用者端的低風險資訊洩漏，因為最容易修補
ACD	24. 某製造業產線遭受勒索軟體攻擊，系統檔案遭到加密。在啟動營運持續計畫（BCP）進行復原時，下列哪些步驟是確保「安全復原」的必要措施？（複選） (A) 在復原備份資料前，必須先隔離受感染網段並驗證備份檔的完整性 (B) 立即支付贖金以取得解密金鑰，這是回復速度最快的方式 (C) 找出入侵破口（Root Cause）並完成修補後，才將系統重新上線 (D) 重建系統時，強制重設所有特權帳號的密碼與憑證

答案	題目
C	25. 【題組 3】情境如附圖所示。身為 S 公司的資安事件應變小組（CSIRT）負責人，在「使用者與實體行為分析（UEBA）」系統發出警報後，應變小組確認內部核心伺服器正發生資料異常外流。依據資安事件應變的最佳實務，在下列選項中，最適合的第一步應對措施為下列何項？ 位於新竹科學園區的頂尖半導體設計公司「S 公司」，其核心資產為存放於本地資料中心的 IC 設計藍圖。為加速全球供應鏈協作，公司正在導入一套建構於雲端原生（Cloud-Native）環境的供應鏈管理（SCM）平台。該平台的開發流程採用 CI/CD（持續整合/持續部署）模式，並引入了生成式 AI 工具以輔助工程師撰寫程式碼。某日，公司的資安監控中心（SOC）接獲 AI 驅動的「使用者與實體行為分析（UEBA）」系統警報，指出有異常的大量資料從 IC 設計藍圖伺服器被存取，疑似資料外洩。經初步調查，攻擊者是透過 SCM 平台所使用的一個第三方開源函式庫漏洞（供應鏈攻擊）滲透，並利用一個設定不當的網路存取規則，從雲端環境橫向移動至本地資料中心。 (A) 立即對外公告公司系統遭駭，以示資訊透明 (B) 嘗試反向追蹤攻擊來源 IP 位址，找出攻擊者身分 (C) 依據預定的應變計畫，立即隔離受駭伺服器 (D) 為了確保服務正常運作，立即重新安裝相關系統

答案	題目
B	26. 【題組 3】情境如附圖所示。身為 S 公司的資安事件應變小組（CSIRT）負責人，事後分析確認，攻擊的初始破口來自雲端供應鏈管理（SCM）平台的一個開源函式庫漏洞。為了系統性地處理這類「軟體供應鏈安全」風險，下列何種安全架構規劃實務最為適切？ 位於新竹科學園區的頂尖半導體設計公司「S 公司」，其核心資產為存放於本地資料中心的 IC 設計藍圖。為加速全球供應鏈協作，公司正在導入一套建構於雲端原生（Cloud-Native）環境的供應鏈管理（SCM）平台。該平台的開發流程採用 CI/CD（持續整合/持續部署）模式，並引入了生成式 AI 工具以輔助工程師撰寫程式碼。某日，公司的資安監控中心（SOC）接獲 AI 驅動的「使用者與實體行為分析（UEBA）」系統警報，指出有異常的大量資料從 IC 設計藍圖伺服器被存取，疑似資料外洩。經初步調查，攻擊者是透過 SCM 平台所使用的一個第三方開源函式庫漏洞（供應鏈攻擊）滲透，並利用一個設定不當的網路存取規則，從雲端環境橫向移動至本地資料中心。 (A) 僅採購有信譽的大廠軟體，並完全信任其安全性 (B) 導入軟體物料清單（Software Bill of Materials, SBOM）管理，並在 CI/CD 流程中整合靜態與動態應用程式安全測試（SAST/DAST） (C) 要求所有開發人員必須精通安全編碼，並負起全部安全責任 (D) 為公司投保高額網路安全險，將所有供應鏈風險完全轉移

答案	題目
C	27. 【題組 3】情境如附圖所示。身為 S 公司的資安事件應變小組（CSIRT）負責人，在本次事件中，攻擊者能從雲端橫向移動至本地核心網路，凸顯了現有安全架構的嚴重缺陷。在規劃下一代安全架構時，下列何種策略最「不」能解決此問題？ 位於新竹科學園區的頂尖半導體設計公司「S 公司」，其核心資產為存放於本地資料中心的 IC 設計藍圖。為加速全球供應鏈協作，公司正在導入一套建構於雲端原生（Cloud-Native）環境的供應鏈管理（SCM）平台。該平台的開發流程採用 CI/CD（持續整合/持續部署）模式，並引入了生成式 AI 工具以輔助工程師撰寫程式碼。某日，公司的資安監控中心（SOC）接獲 AI 驅動的「使用者與實體行為分析（UEBA）」系統警報，指出有異常的大量資料從 IC 設計藍圖伺服器被存取，疑似資料外洩。經初步調查，攻擊者是透過 SCM 平台所使用的一個第三方開源函式庫漏洞（供應鏈攻擊）滲透，並利用一個設定不當的網路存取規則，從雲端環境橫向移動至本地資料中心。 (A) 升級邊界防火牆，購買具備更高吞吐量的設備 (B) 實施零信任安全架構（ZTA），廢除傳統信任邊界，對所有存取請求進行嚴格驗證與授權 (C) 要求所有雲端與本地系統的管理者使用相同的帳號密碼，以利於管理 (D) 建立一個獨立的實體隔離網路（Air-gapped Network），將 IC 設計部門與公司其他網路完全隔絕

答案	題目
ABD	28. 【題組 3】情境如附圖所示。身為 S 公司的資安事件應變小組（CSIRT）負責人，為了從管理與技術層面全面強化公司的資安管理系統（ISMS），避免未來發生類似的複合式攻擊，管理層應推動下列哪些措施？（複選） 位於新竹科學園區的頂尖半導體設計公司「S 公司」，其核心資產為存放於本地資料中心的 IC 設計藍圖。為加速全球供應鏈協作，公司正在導入一套建構於雲端原生（Cloud-Native）環境的供應鏈管理（SCM）平台。該平台的開發流程採用 CI/CD（持續整合/持續部署）模式，並引入了生成式 AI 工具以輔助工程師撰寫程式碼。某日，公司的資安監控中心（SOC）接獲 AI 驅動的「使用者與實體行為分析（UEBA）」系統警報，指出有異常的大量資料從 IC 設計藍圖伺服器被存取，疑似資料外洩。經初步調查，攻擊者是透過 SCM 平台所使用的一個第三方開源函式庫漏洞（供應鏈攻擊）滲透，並利用一個設定不當的網路存取規則，從雲端環境橫向移動至本地資料中心。 (A) 定期執行包含供應鏈攻擊情境的紅隊演練（Red Teaming），驗證整體防護與應變能力 (B) 更新資安政策，明確納入對生成式 AI 輔助工具的使用規範與風險控管要求 (C) 為了節省成本，將所有資安監控業務完全外包，並減少內部資安人員編制 (D) 強化存取控制實務，針對關鍵資產導入特權帳號管理（PAM）與即時（Just-in-Time）存取機制
A	29. 網站應用程式安全測試中，盲注式 SQL 注入攻擊（Blind SQL Injection）的測試比一般 SQL 注入攻擊更具挑戰，以下描述何者最正確？ (A) 難以透過錯誤訊息來洩漏資料庫資訊，而透過行為模式（如：時間延遲回應）推斷資料 (B) 盲注式 SQL 注入只會影響後端資料庫，不會影響應用程式的前端 (C) 盲注式 SQL 注入需要特定的自動化工具，無法手動執行 (D) 若發生在無法存取原始碼的黑箱測試情境中，偵測更加困難
B	30. 對手機應用程式透過逆向工程（Reverse Engineering）執行安全檢測時，常可觀察到存在混淆（Obfuscation）等技巧，關於該機制之描述，下列何者最正確？ (A) 使手機應用程式完全無法被逆向工程 (B) 透過轉換程式碼和資料，提高理解和反組譯的困難度 (C) 加速手機應用程式的執行速度 (D) 減少手機應用程式的檔案大小

答案	題目
B	31. 下列何項做法，最能有效提升滲透測試及源碼檢測的整體覆蓋率與準確度？ (A) 依賴自動化掃描工具（例如 Nessus、Burp Suite 自動掃描、自動分析），完全不進行人工驗證或複測 (B) 在滲透測試前進行 Threat Modeling（威脅建模），再結合源碼檢測的結果，將高風險模組作為人工滲透測試的優先目標 (C) 每年只做一次資安健診，不管系統更新與程式版本是否有變動 (D) 做滲透測試即可，源碼檢測與資安健診會造成資源浪費
ABC	32. 某組織為提升整體資訊安全水準，規劃針對其對外服務系統進行安全檢測。該系統包含自行開發的應用程式，並整合多項第三方元件，同時已正式上線並提供實際服務。管理階層希望透過不同安全測試方式，從設計缺陷、根據上述情境，下列哪些說法最符合滲透測試、源碼檢測與資安健診在實務上的正確定位與整合應用方式？（複選） (A) 滲透測試可模擬攻擊者實際入侵行為，用以驗證弱點是否能在真實環境中被成功利用 (B) 資安健診著重於組織整體防護機制與管理流程，屬於策略與制度層級的安全檢視 (C) 源碼測試可在不實際攻擊系統的情況下，檢視應用程式設計與實作上的潛在安全缺陷 (D) 只要完成源碼測試，即可取代滲透測試與資安健診的必要性

答案	題目
C	33. 【題組 4】情境如附圖所示。若測試人員將 orderId 改為其他數值後成功取得不同使用者訂單資料，此弱點最適合歸類為下列何種弱點類別？ 某企業進行 Web 應用程式滲透測試，測試人員以一般使用者帳號登入後，發現可透過修改 API 參數存取其他使用者的訂單資料。以下為測試時攔截到的部分請求內容： GET /api/order/detail?orderId=10025 HTTP/1.1 Host: securityshop.csf.org.tw Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIyMDI1MTIzMCIsIm5hbWUiOiJpUEFTIFNlY3VyaXR5IEVuZ2luZWVyIiwiYWRtaW4iOnRydWUsImlhdCI6MzE0MTU5MjY1M30.YPEZ_8lwWcOyTdsZFnSu7dTKA0xsz-p1U5zRN3yRfQQ (A) Security Misconfiguration（不安全的組態設定） (B) Insecure Deserialization（不安全的反序列化） (C) Broken Access Control（無效的訪問控制） (D) Security Logging & Alerting Failures（安全日誌及警報失效）

答案	題目
D	34. 【題組 4】情境如附圖所示。承上題，下列何者較可解決此一問題？ 某企業進行 Web 應用程式滲透測試，測試人員以一般使用者帳號登入後，發現可透過修改 API 參數存取其他使用者的訂單資料。以下為測試時攔截到的部分請求內容： GET /api/order/detail?orderId=10025 HTTP/1.1 Host: securityshop.csf.org.tw Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIyMDI1MTIzMCIsIm5hbWUiOiJpUEFTIFNlY3VyaXR5IEVuZ2luZWVyIiwiYWRtaW4iOnRydWUsImlhdCI6MzE0MTU5MjY1M30.YPEZ_8lwWcOyTdsZFnSu7dTKA0xsz-p1U5zRN3yRfQQ (A) 登入後還必須加上雙因子驗證才能防範 (B) API 應該加上次數限制 (C) 在網頁前端進行授權檢查即可解決 (D) 將相關參數雜湊加鹽隱碼處理

答案	題目
C	35. 【題組 4】情境如附圖所示。下列何項「不」是這個漏洞可能造成的影響？ 某企業進行 Web 應用程式滲透測試，測試人員以一般使用者帳號登入後，發現可透過修改 API 參數存取其他使用者的訂單資料。以下為測試時攔截到的部分請求內容： GET /api/order/detail?orderId=10025 HTTP/1.1 Host: securityshop.csf.org.tw Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIyMDI1MTIzMCIsIm5hbWUiOiJpUEFTIFNlY3VyaXR5IEVuZ2luZWVyIiwiYWRtaW4iOnRydWUsImlhdCI6MzE0MTU5MjY1M30.YPEZ_8lwWcOyTdsZFnSu7dTKA0xsz-p1U5zRN3yRfQQ (A) 企業可能會被使用者控告違反 GDPR（General Data Protection Regulation） (B) 如果企業的開發習慣不佳，其他功能可能也會有類似的漏洞，需要全盤檢視類似功能的設計方式 (C) 攻擊者可以用這個漏洞直接列出資料庫的所有欄位，導致資料庫結構全部外洩 (D) 使用者可能會因為這些資料外洩而接到詐騙電話

答案	題目
ABC	36. 【題組 4】情境如附圖所示。關於測試人員在 HTTP Header 中看到的 Authorization 內容，下列哪些描述是正確的？（複選） 某企業進行 Web 應用程式滲透測試，測試人員以一般使用者帳號登入後，發現可透過修改 API 參數存取其他使用者的訂單資料。以下為測試時攔截到的部分請求內容： GET /api/order/detail?orderId=10025 HTTP/1.1 Host: securityshop.csf.org.tw Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIyMDI1MTIzMCIsIm5hbWUiOiJpUEFTIFNlY3VyaXR5IEVuZ2luZWVyIiwiYWRtaW4iOnRydWUsImlhdCI6MzE0MTU5MjY1M30.YPEZ_8lwWcOyTdsZFnSu7dTKA0xsz-p1U5zRN3yRfQQ (A) 會使用 HS256（HMAC with SHA-256）來驗證 token 內容 (B) 會使用 Base64 進行編碼 (C) 會使用 RS256（RSA with SHA-256）來驗證 token 內容 (D) 如果使用 alg: none 代表不指定演算法，預設採用最高層級的驗證方式
B	37. 【題組 5】情境如附圖所示。若欲確認 SQL 注入是否存在，下列何者為最適合的測試語法？ 某銀行委託資安團隊對新版線上金融交易系統執行資安檢測，包含滲透測試、原始碼檢測及整體資安健診。在滲透測試過程中，資安團隊成功繞過前端 WAF，發現系統可透過交易金額欄位進行 SQL 注入（SQL Injection）。在原始碼檢測時，資安團隊發現開發人員未使用參數化查詢（Parameterized Query），而直接拼接字串。 (A) <script>alert(1)</script> (B) OR '1'='1' -- (C) %00%ff%fe%fd (D) <entity SYSTEM="file:///etc/passwd">

答案	題目
A	38. 【題組 5】情境如附圖所示。針對 SQL 注入測試，下列哪一個觀念最「不」適切？ 某銀行委託資安團隊對新版線上金融交易系統執行資安檢測，包含滲透測試、原始碼檢測及整體資安健診。在滲透測試過程中，資安團隊成功繞過前端 WAF，發現系統可透過交易金額欄位進行 SQL 注入（SQL Injection）。在原始碼檢測時，資安團隊發現開發人員未使用參數化查詢（Parameterized Query），而直接拼接字串。 (A)' OR '1'='1' -- 是非常萬用的語法，通常可以有效測出 SQL Injection 存在與否，對測試標的影響程度低，無論是在資料庫的新增、刪除、修改都可以直接使用 (B)'; DROP TABLE Products;# 這種語法會導致刪除整張資料表，通常不會在實戰過程中使用這種語法 (C)'; IF (1=1) WAITFOR DELAY '0:0:10'-- 這種語法會導致伺服器延遲 10 秒再回應，有可能會讓使用者感受到效能異常，必須謹慎使用 (D)在特定情境下，施測人員可以透過 INTO OUTFILE 這種功能寫入後門到資料庫伺服器中，並且透過該後門達成 Remote Code Execution
C	39. 【題組 5】情境如附圖所示。防範 SQL 注入弱點時，下列哪一個觀念最「不」適切，最難有效阻止 SQL 注入？ 某銀行委託資安團隊對新版線上金融交易系統執行資安檢測，包含滲透測試、原始碼檢測及整體資安健診。在滲透測試過程中，資安團隊成功繞過前端 WAF，發現系統可透過交易金額欄位進行 SQL 注入（SQL Injection）。在原始碼檢測時，資安團隊發現開發人員未使用參數化查詢（Parameterized Query），而直接拼接字串。 (A)使用參數化查詢（Prepared Statements） (B)使用正則表示式（Regular Expression）過濾輸入值，限制輸入字元的內容 (C)限制參數的輸入字元長度，將長度控制在 50 個字元以內 (D)採用最小權限原則，並且關閉錯誤訊息，減少攻擊者可獲得的權限和資訊

答案	題目
BD	40. 【題組 5】情境如附圖所示。資安測試團隊嘗試繞過前端 WAF 時，下列哪些方式最「不」可能達成目的（成功率最低）？（複選） 某銀行委託資安團隊對新版線上金融交易系統執行資安檢測，包含滲透測試、原始碼檢測及整體資安健診。在滲透測試過程中，資安團隊成功繞過前端 WAF，發現系統可透過交易金額欄位進行 SQL 注入（SQL Injection）。在原始碼檢測時，資安團隊發現開發人員未使用參數化查詢（Parameterized Query），而直接拼接字串。 (A) 使用編碼（Encoding）技巧，如 URL Encoding 或 Unicode，透過不同的編碼方式來混淆攻擊 Payload，讓 WAF 無法正確偵測 (B) 透過多個 Proxy 或 VPN 變換 IP 位址，讓 WAF 以為是不同的來源，就不會對 SQL 注入語法進行阻擋 (C) 透過刻意修改 Payload 中的關鍵字或語法，避開 WAF 黑名單規則，例如將 SQL 注入語法裡面的 or 改用 || (D) 使用 ARP 欺騙（ARP Spoofing）進行網路封包攔截，直接竄改封包內容即可繞過 WAF

《以下空白》